

Lfi Y Path Traversal

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Un parametro cuyo valor parece un nombre de fichero o de pagina (?page=home, ?file=report).
- La respuesta cambia de forma coherente al pedir rutas: ../ te acerca a la raiz, un fichero inexistente da un error de include con la ruta.
- Puedes leer un log (access.log, auth.log) via la LFI: el log refleja datos que tu envias, como el User-Agent.
- Existe una subida de ficheros que no valida bien la extension o el contenido.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>curl -s '\$URL/?page=../../../../.etc/passwd'</code>	Prueba de lectura con un fichero que siempre existe. Los ../ de sobra suben hasta la raiz aunque no sepas la profundidad real del script.	Lineas root:x:0:0. Si aparecen, hay LFI confirmada. Un error de include con una ruta absoluta tambien es util: te dice donde estas en el disco.
<code>curl -s '\$URL/?page=php://filter/convert.base64-encode/resource=config'</code>	Si el codigo anade .php y ejecuta el fichero, el wrapper php://filter te deja leer el FUENTE en base64 sin que se ejecute. Asi lees configs con credenciales.	Un blob en base64: decodificalo (base64 -d) para ver el codigo PHP. Busca ahi credenciales de BD, claves de API y rutas a otros ficheros jugosos.
<code>curl -s '\$URL/?page=../../../../var/log/apache2/access.log&c=id'</code>	Log poisoning: antes mandas PHP en tu User-Agent (queda escrito en el access.log) y ahora incluyes ese log via la LFI. El servidor interpreta tu PHP y ejecuta el comando de ?c=.	La salida de id incrustada entre las lineas del log confirma ejecucion. Fijate en el usuario (www-data): es con quien tendras la shell al escalar a reverse shell.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.